

# SEC-PREPROD-02 — Audit Evidence

Patch di hardening pre-produzione. Documento di evidenza allegabile al report auditor finale.

| Campo                              | Valore                                                                                                                                                         |
|------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Identificativo patch               | SEC-PREPROD-02                                                                                                                                                 |
| Data                               | 2026-05-16                                                                                                                                                     |
| Branch                             | main                                                                                                                                                           |
| Commit HEAD al momento della patch | f8005f8 (*Harden asset assignment and release guard*)                                                                                                          |
| Stato commit patch                 | Non committata al momento della redazione di questo documento (working tree)                                                                                   |
| Origine                            | Secondo audit read-only su moduli non coperti a fondo dal primo audit                                                                                          |
| Scope                              | 1 finding High + 3 Medium (H1, M1, M2, M3)                                                                                                                     |
| Vincoli rispettati                 | Patch minima · nessun refactor · nessuna nuova dipendenza · nessun cambio DB/migrazioni · nessun cambio URL · nessun cambio UX · ACL middleware non indebolito |

## 1. Finding chiusi

| Finding                                                                            | Severità | Stato                      | Patch                                                                                                               | Test                                                       |
|------------------------------------------------------------------------------------|----------|----------------------------|---------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------|
| H1 — rilevazione_incidenti.export_pdf: nessun controllo ruolo / IDOR su PII        | High     | Chiuso                     | Gate is_superuser OR _can_manage_rssp OR _can_create prima della generazione PDF; risorsa mancante -> Http404 reale | ExportPdfAuthorizationTests (5 test)                       |
| M2 — timbri._download_image: SSRF / leak token Graph verso URL da lista SharePoint | Medium   | Chiuso                     | Helper _is_graph_trusted_host + allowlist host Microsoft Graph/SharePoint                                           | TimbriDownloadImageHostAllowlistTests (5 test)             |
| M3 — rentri: CRUD registro rifiuti senza gate ruolo esplicito                      | Medium   | Chiuso                     | Helper _can_manage_rentri + _require_rentri_manager su 5 endpoint di scrittura                                      | RentriWriteAuthorizationTests (8 test)                     |
| M1 — rilevazione_incidenti: viste di lettura senza difesa in profondità            | Medium   | Chiuso <b>parzialmente</b> | @login_required su 9 viste del modulo                                                                               | ReadViewsAuthGuardTests, ReadViewsAuthenticatedAccessTests |

**Nota su M1 (chiusura parziale):** è stato aggiunto @login\_required come difesa in profondità. **Non** è stato implementato lo scoping per-proprietario su dettaglio/lista perché il modello RilevazioneIncidente non possiede un campo proprietario/autore (created\_by/owner): il campo nominativo è testo libero. Un controllo per-oggetto richiederebbe refactor + nuovo campo DB, fuori dallo scope di patch minima. Vedi §6 Rischi residui.

## 2. File modificati

| File                                      | Motivo security                                                                                                            | Tipo modifica   |
|-------------------------------------------|----------------------------------------------------------------------------------------------------------------------------|-----------------|
| django_app/rilevazione_incidenti/views.py | H1: gate ruolo su export_pdf + fix 404 reale (eliminato template forbidden con status 404); M1: @login_required su 9 viste | Modifica codice |
| django_app/rilevazione_incidenti/tests.py | Copertura test H1 + M1                                                                                                     | Modifica test   |
| django_app/timbri/views.py                | M2: helper _is_graph_trusted_host + allowlist token Graph in _download_image                                               | Modifica codice |
| django_app/timbri/tests.py                | Copertura test M2                                                                                                          | Modifica test   |

| File                       | Motivo security                                                           | Tipo modifica   |
|----------------------------|---------------------------------------------------------------------------|-----------------|
| django_app/rentri/views.py | M3: helper _can_manage_rentri/_require_rentri_manager + gate su scritture | Modifica codice |
| django_app/rentri/tests.py | Copertura test M3                                                         | Nuovo file      |
| CHANGELOG.md               | Tracciabilità security — voce [Unreleased] / Security                     | Modifica doc    |

*Nota operativa: alcuni file target avevano l'attributo Windows read-only; rimosso temporaneamente per applicare la patch. Nessun impatto sul contenuto.*

### 3. Policy implementate

#### H1 — [rilevazione\\_incidenti.export\\_pdf](#)

Generazione PDF consentita solo se `request.user.is_superuser` OR `_can_manage_rspp(request)` OR `_can_create(request)` — gestori sicurezza, preposti, RSPP, amministratori. Accesso negato -> 403 reale con template `core/pages/forbidden.html`. Rilevazione inesistente o non recuperabile -> `Http404` (rimosso il bug "template forbidden con status 404 incoerente"). Nessun ruolo nuovo introdotto: riusati gli helper già presenti nel modulo.

#### M2 — [timbri.\\_download\\_image](#)

Nuovo helper `_is_graph_trusted_host(url)`: accetta solo schema `http/https` verso host in allowlist — `graph.microsoft.com`, `*.graph.microsoft.com`, `*.sharepoint.com`. `_download_image` rifiuta (`RuntimeError`, nessuna chiamata `requests.get`) ogni URL fuori allowlist, privo di hostname o con schema non valido. Il bearer token Graph non viene mai inviato a host non attendibili. Timeout 30s preesistente mantenuto. Token mai loggato.

#### M3 — [rentri \(scritture registro rifiuti\)](#)

Nuovo helper `_can_manage_rentri(request)` (`superuser` o `admin legacy`) e `_require_rentri_manager(request)` che ritorna `JsonResponse 403`. Applicato a tutte le operazioni di scrittura: carico/scarico \*/rettifica (`_handle_form`, branch POST), modifica (branch POST), elimina, `import_confirm`, `api_sync_pull`. Lettura (elenco, `export_pdf`, `import_preview`) invariata, secondo ACL di modulo. elimina resta `@require_POST`.

#### M1 — [rilevazione\\_incidenti \(difesa in profondità\)](#)

`@login_required` aggiunto a lista, dettaglio, modifica, elimina, statistiche, heatmap, impostazioni, `export_csv`, `export_pdf`. Il middleware ACL resta la difesa primaria; il decoratore è ridondanza intenzionale.

### 4. Comandi eseguiti — esiti

| Comando                                                                                                                                                         | Esito   | Sintesi output                                                                   |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|---------|----------------------------------------------------------------------------------|
| <code>python manage.py check --settings=config.settings.test</code>                                                                                             | [OK] OK | System check identified no issues (0 silenced)                                   |
| <code>python manage.py makemigrations --check --dry-run --settings=config.settings.test</code>                                                                  | [OK] OK | No changes detected — nessuna migrazione, coerente con il vincolo "no DB change" |
| <code>python manage.py test rilevazione_incidenti.tests timbri.tests.TimbriDownloadImageHost AllowlistTests rentri.tests --settings=config.settings.test</code> | [OK] OK | Ran 24 tests ... OK — tutti i test nuovi della patch passano                     |
| <code>python manage.py test core.tests tickets.tests admin_portale.tests --settings=config.settings.test (baseline)</code>                                      | [OK] OK | Ran 235 tests ... OK                                                             |

| Comando                                                                                                                                                  | Esito       | Sintesi output                                                                                                                                                                                                                    |
|----------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| python manage.py test core.tests tickets.tests admin_portale.tests rilevazione_incidenti.tests timbri.tests rentri.tests --settings=config.settings.test | [!] FAILED  | Ran 277 tests — FAILED (failures=3, errors=1); i 4 falli sono <b>preesistenti</b> in timbri.tests (vedi §5)                                                                                                                       |
| python manage.py acl_coverage_report --include-admin --format json --fail-on-missing --max-missing 0 --settings=config.settings.test                     | [X] FALLITA | ACL coverage check failed: 76 route applicative senza binding canonico — gap <b>preesistente</b> (vedi §6)                                                                                                                        |
| git diff --check (file della patch)                                                                                                                      | [OK] OK     | Nessun problema di whitespace nei file SEC-PREPROD-02                                                                                                                                                                             |
| git status --short                                                                                                                                       | —           | M CHANGELOG.md, M django_app/rentri/views.py, M django_app/rilevazione_incidenti/tests.py, M django_app/rilevazione_incidenti/views.py, M django_app/timbri/tests.py, M django_app/timbri/views.py, ?? django_app/rentri/tests.py |

#### Test aggiunti dalla patch (24 totali, tutti verdi in esecuzione isolata):

- ExportPdfAuthorizationTests — 5: basic user -> 403; RSPP -> 200; superuser -> 200; sp\_id inesistente -> 404; regressione "403 negato / 404 assente" coerente.
- ReadViewsAuthGuardTests + ReadViewsAuthenticatedAccessTests — anonimo -> redirect login; utente autenticato -> accesso funzionante.
- TimbriDownloadImageHostAllowlistTests — 5: host graph.microsoft.com/\*.sharepoint.com -> Authorization inviato; host non attendibile -> non scaricato; sharepoint.com solo in query -> rifiutato; schema/host mancante -> rifiutato.
- RentriWriteAuthorizationTests — 8: utente base bloccato su create/modify/delete/import/sync (403, dato invariato); admin consentito; GET su elimina -> 405.

*Test funzionale end-to-end su browser reale non eseguito: la patch non introduce JS; i finding sono coperti da test server-side.*

## 5. Failure preesistenti (NON introdotte dalla patch)

Le seguenti failure di timbri.tests sono **preesistenti**. Confermato eseguendo timbri.tests sul codice **pre-patch** via git stash delle modifiche timbri: esito identico FAILED (failures=3, errors=1).

| Test                                                                                       | Tipo              | Causa apparente                                                   |
|--------------------------------------------------------------------------------------------|-------------------|-------------------------------------------------------------------|
| TimbriViewTests.test_caporeparto_can_view_but_cannot_create                                | FAIL (302 != 200) | Redirect onboarding per utente non-superuser senza UserOnboarding |
| TimbriAnagraficaIntegrationTests.test_anagrafica_list_shows_timbri_link                    | FAIL (302 != 200) | Idem                                                              |
| TimbriDownloadAuditTests.test_se_rve_timbri_image_denied_creates_denied_audit_without_path | FAIL (302 != 403) | Idem                                                              |
| TimbriViewTests.test_reset_table_deduplicates_uppercase_legacy_rows                        | ERROR             | Deduplica righe legacy uppercase                                  |

**Nota su non-determinismo:** una esecuzione della suite estesa a 6 moduli ha riportato failures=8, una successiva failures=3 — flakiness **preesistente** di isolamento test tra app (tabella raw anagrafica\_dipendenti / file sqlite in .tmp\_tests). Le suite core.tests tickets.tests admin\_portale.tests eseguite da sole danno **235 test OK** stabili; le suite della patch (rilevazione\_incidenti.tests, rentri.tests, classe M2 di timbri) danno **24**

test OK stabili. Il non-determinismo non riguarda i moduli toccati dalla patch.

## 6. Rischi residui

| Rischio                                                                                                                                                                                                             | Owner consigliato      | Priorità | Scadenza consigliata                      | Motivazione accettabilità in produzione                                                                                                                                                                                                                        |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------|----------|-------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>76 route applicative senza</b> RoutePermissionsBinding <b>canonico</b> — acl_coverage_report --max-missing 0 fallisce                                                                                            | Team ACL / Platform    | Media    | Patch ACL dedicata prima della GA         | Gap <b>preesistente</b> : il baseline documentato del progetto è --max-missing 222; la patch non aggiunge né rimuove route. Il middleware ACL + fallback legacy resta attivo e autoritativo. Come da istruzioni, l'ACL non è stata modificata.                 |
| <b>4 test preesistenti falliti</b> in timbri.tests (3 FAIL + 1 ERROR)                                                                                                                                               | Owner modulo Timbri    | Bassa    | Backlog QA, da chiarire prima del go-live | <b>Preesistenti</b> , confermati su codice pre-patch; non di natura security. Non bloccano il deploy ma vanno investigati.                                                                                                                                     |
| <b>Scoping per-owner</b> rilevazione_incidenti <b>non implementato</b>                                                                                                                                              | Owner modulo Sicurezza | Bassa    | Da decidere con il business               | Il modello Rilevazione Incidente non ha campo created_by/owner: lo scoping richiederebbe refactor + cambio DB, fuori scope. H1 chiude comunque l'esposizione PDF; la lista incidenti è plausibilmente a trasparenza di reparto. <b>Needs manual decision.</b>  |
| <b>Finding Low L1–L4 non chiusi</b> — L1 CSV/formula injection negli export; L2 newline injection .env timbri; L3 whitelist vuota rilevazione_incidenti (fail-open); L4 validazione debole api_parse_sharepoint_url | Team Security          | Bassa    | Patch successive (già pianificate)        | Esplicitamente esclusi dallo scope di SEC-PREPROD-02. Impatto limitato: L1 richiede apertura in Excel da utenti interni; L2 è admin-only; L3 è comportamento documentato; L4 non risulta sfruttabile come SSRF (host di richiesta sempre graph.microsoft.com). |
| <b>Flakiness isolamento test</b> nella suite estesa multi-app                                                                                                                                                       | Team QA                | Bassa    | Backlog QA                                | Non di sicurezza; non blocca il deploy.                                                                                                                                                                                                                        |

## 7. Go / No-Go

**GO** — per i finding in scope (H1, M2, M3 chiusi; M1 chiuso come difesa in profondità).

- Nessuna regressione introdotta: manage.py check pulito, nessuna migrazione, baseline core/tickets/admin\_portale **235 test OK**, test della patch **24 OK**.
- Le sole failure rilevate (4 in timbri.tests) sono **preesistenti e confermate** sul codice pre-patch.

**Condizioni residue** — non bloccanti per questa patch, da indirizzare prima della GA con patch separate:

- Copertura ACL: 76 route senza binding canonico (patch ACL dedicata).
- Decisione manuale sullo scoping per-proprietario di rilevazione\_incidenti.
- Chiusura dei Low L1–L4.

4 Investigazione dei 4 test preesistenti falliti in `timbri.tests`.

Il Go è quindi **condizionato**: la patch SEC-PREPROD-02 può essere rilasciata, ma il go-live di produzione resta subordinato al follow-up dei punti 1–4.